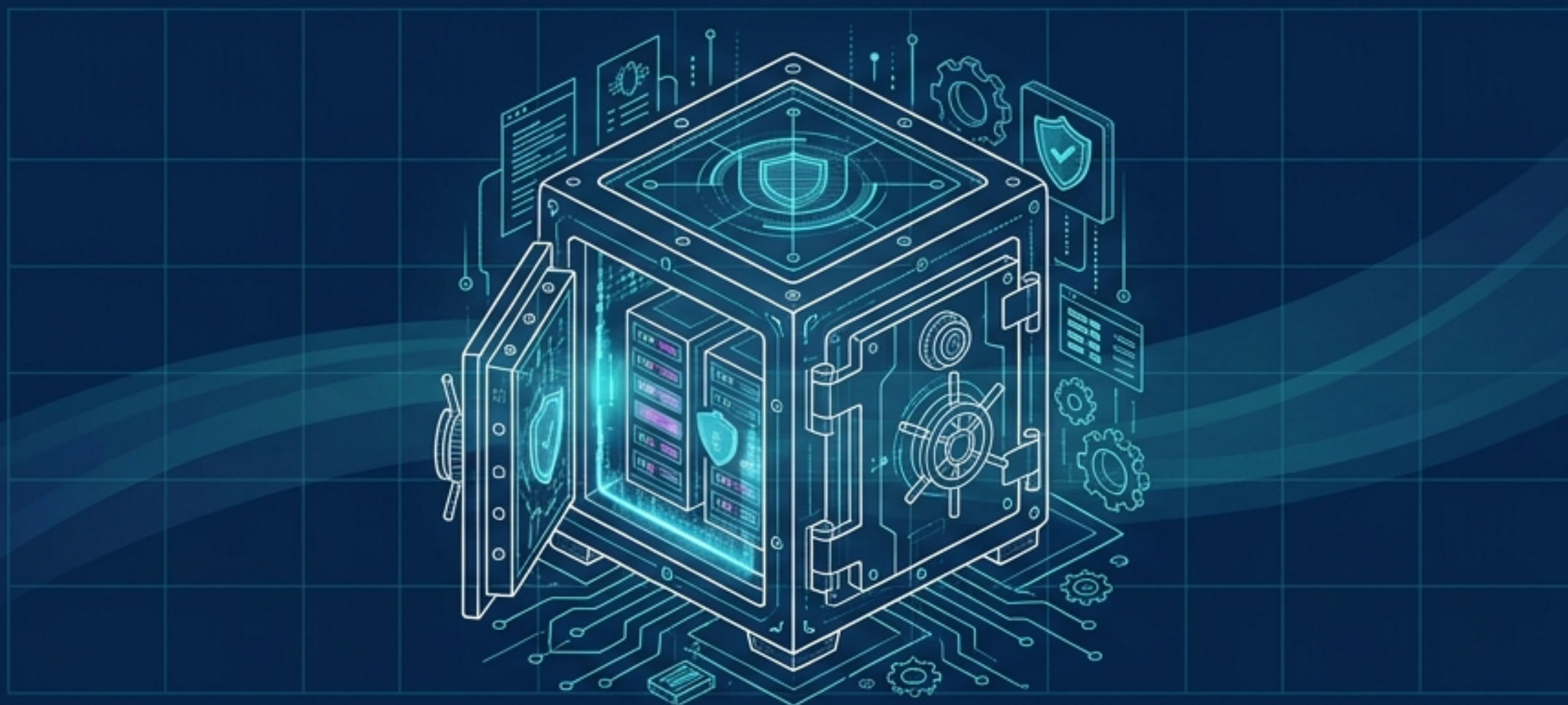
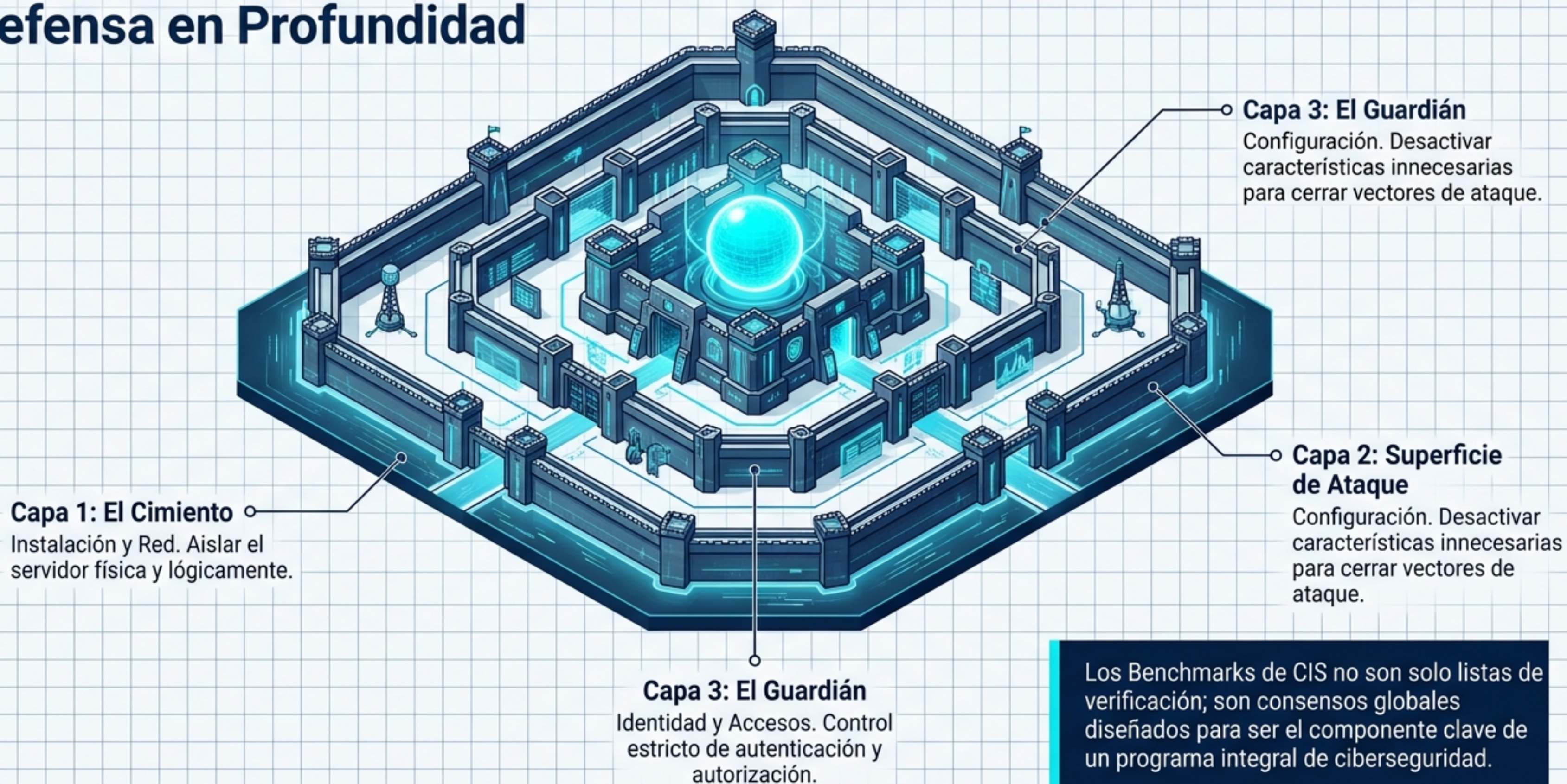




El Plano de Seguridad: CIS Benchmark para SQL Server 2022

Estrategias de Defensa en Profundidad para blindar
el motor de base de datos

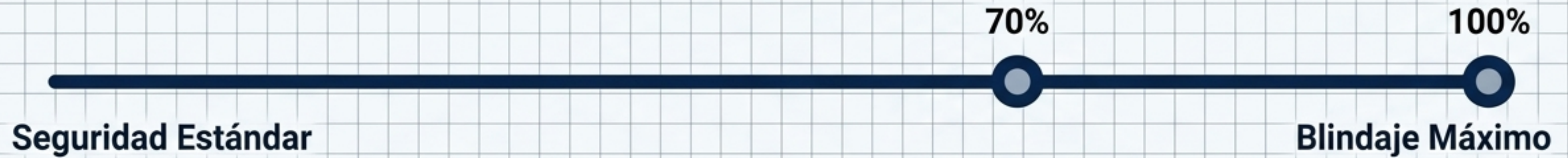
La Filosofía CIS: Defensa en Profundidad



Los Benchmarks de CIS no son solo listas de verificación; son consensos globales diseñados para ser el componente clave de un programa integral de ciberseguridad.

Matriz de Perfiles:

¿Qué nivel de rigor requiere su entorno?



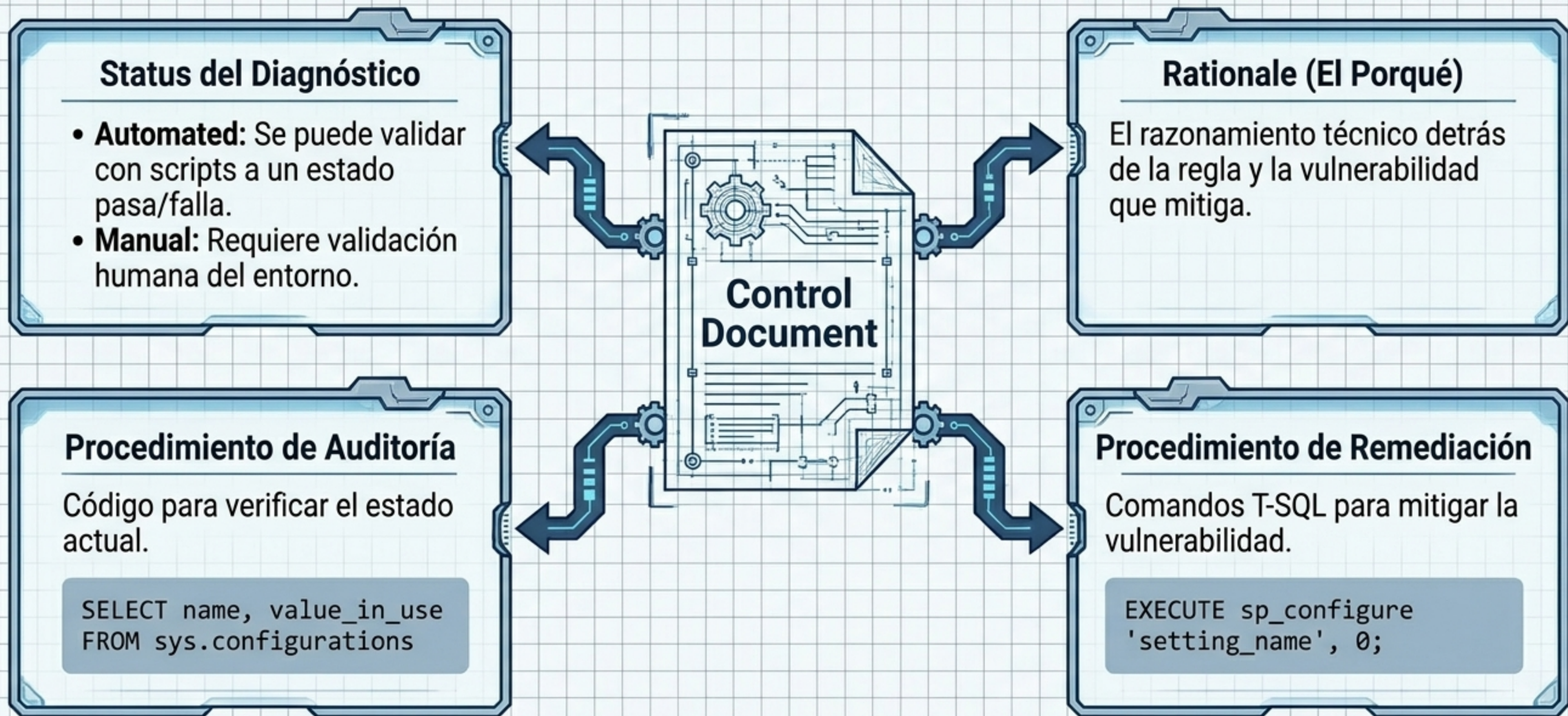
Nivel 1: Database Engine / AWS RDS

- **Objetivo:** Beneficio de seguridad claro, práctico y prudente.
- **Impacto:** NO inhibe la utilidad de la tecnología más allá de los medios aceptables.
- **Casos de uso:** Estándar base recomendado para todos los servidores corporativos.

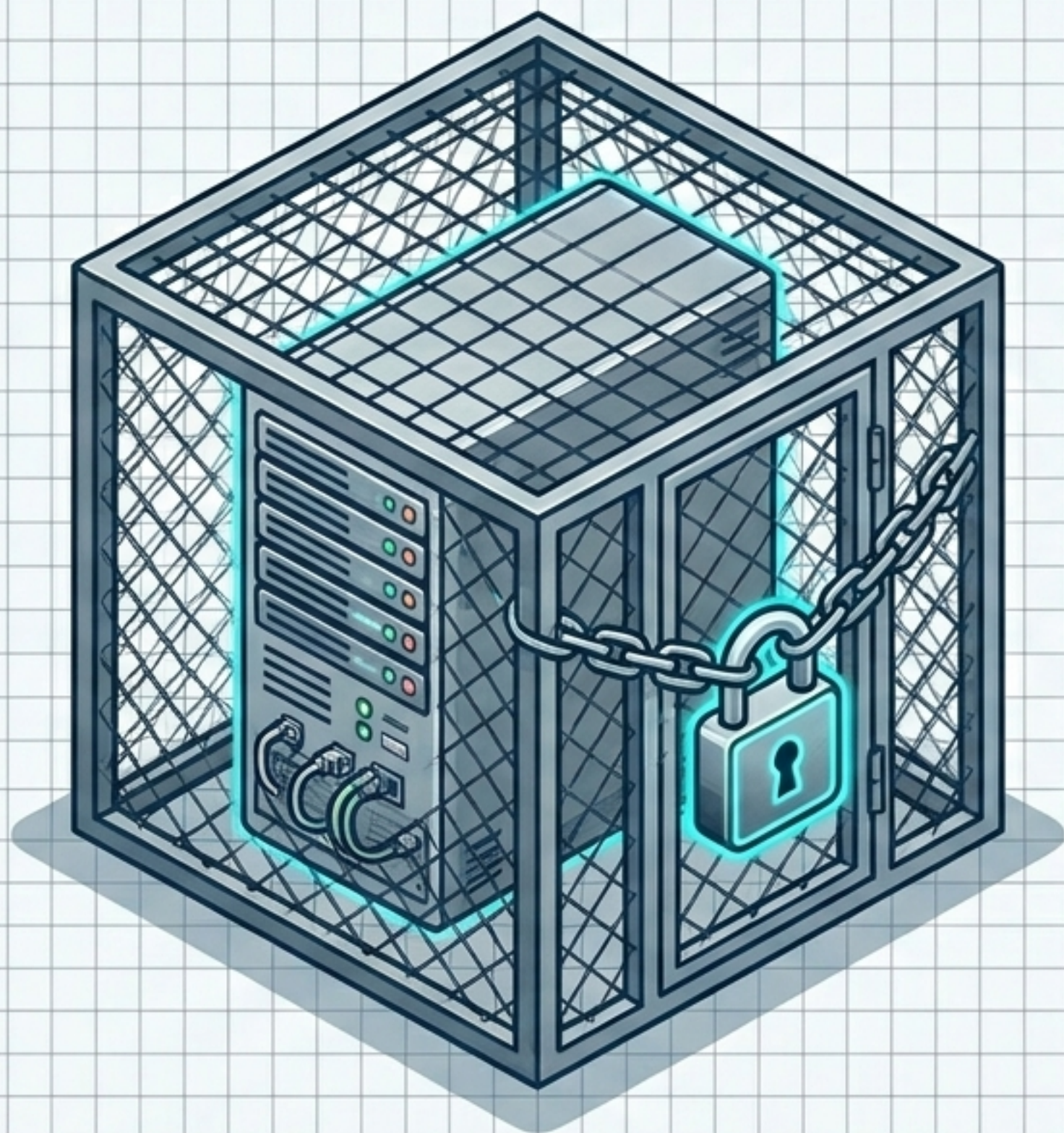
Nivel 2: Database Engine

- **Objetivo:** Medidas estrictas de 'defensa en profundidad'.
- **Impacto:** Puede afectar el rendimiento o la utilidad de ciertas aplicaciones.
- **Casos de uso:** Entornos críticos donde la seguridad es absolutamente primordial.

Anatomía de un Control de Seguridad



Capa 1: El Cimiento y el Aislamiento



Control 1.1: Actualizaciones Acumulativas (Manual)

La seguridad base requiere el software más reciente.
Audite la versión actual ejecutando:

```
SELECT SERVERPROPERTY('ProductLevel')
```

Control 1.2: Servidores de Función Única (Manual)

- **Regla:** SQL Server debe instalarse en un servidor dedicado.
- **Razón:** Minimiza la superficie de ataque del sistema operativo subyacente. No debe haber otros roles o herramientas excesivas instaladas.
- **Impacto:** Segmentación física o lógica estricta para datos de alta sensibilidad.

Capa 2: Reducción de la Superficie de Ataque

De 'Rico en Características' a 'Privilegio Mínimo'



SQL Server ofrece funcionalidades avanzadas (scripts externos, automatización OLE).
Cada función habilitada, pero no utilizada, es un vector de ataque pasivo. La regla de oro del Benchmark CIS es: **Si no lo necesita, desactívelo** (`sp_configure = 0`).

Matriz de Configuraciones Críticas (Parte I)

Característica	Vector de Amenaza	Comando de Remediación T-SQL
Ad Hoc Distributed Queries (2.1)	 Explota vulnerabilidades en instancias remotas / Visual Basic	<pre>sp_configure 'Ad Hoc Distributed Queries', 0</pre>
CLR Enabled (2.2)	 Ejecución de ensamblas maliciosas o inadvertidas	<pre>sp_configure 'clr enabled', 0</pre>
Cross DB Ownership Chaining (2.3)	 Fuga de información cruzada eludiendo permisos	<pre>sp_configure 'cross db ownership chaining', 0</pre>

Matriz de Configuraciones Críticas (Parte II)

Característica	Vector de Amenaza	Comando de Remediación T-SQL
Database Mail XPs (2.4)	! Vector de ataque DoS y canal de exfiltración de datos	<pre>sp_configure 'Database Mail XPs', 0</pre>
Ole Automation Procedures (2.5)	! Ejecuta funciones externas en el contexto de SQL	<pre>sp_configure 'Ole Automation Procedures', 0</pre>
Scan For Startup Procs (2.8)	! Ejecución de código malicioso persistente al reiniciar	<pre>sp_configure 'scan for startup procs', 0</pre>

Nota de Auditoría: Todas las configuraciones se auditan consultando la vista sys.configurations donde value_in_use = 0.

Capa 2.5: Aislamiento de Red y Camuflaje



! Control 2.11: Puertos No Estándar

El puerto por defecto TCP:1433 es ampliamente conocido. Cambiar a un puerto estático no estándar protege contra ataques automatizados.

! Control 2.12: Ocultar Instancia

Cambiar HideInstance a 'Yes' evita que el servicio SQL Server Browser anuncie la instancia en la red de producción. (Precaución: Puede romper clústeres).

! Control 2.10: Gestión de Protocolos

Desactivar protocolos innecesarios en el Configuration Manager; dejar solo TCP/IP y Shared Memory.

Capa 3: Autenticación (El Guardián)



! Control 3.1: Windows Authentication Mode

El Principio: La autenticación de Windows proporciona un mecanismo mucho más robusto que la autenticación nativa de SQL Server (Modo Mixto). Delege la seguridad al directorio activo.

Auditoría:

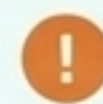
```
SELECT SERVERPROPERTY('IsIntegratedSecurityOnly')
```

Debe retornar el valor 1.

Remediación:

Cambiar la configuración en las propiedades del servidor a Windows Authentication Mode y reiniciar el servicio MSSQL.

Anatomía de una Amenaza: Neutralizando la Cuenta 'sa'



El Problema:

El Problema: 'sa' es el objetivo número uno de ataques de fuerza bruta. Renombrar no es suficiente porque el motor siempre lo identifica por su SID original (0x01).

Fase 1: Renombrar (Control 2.14)

```
ALTER LOGIN sa  
WITH NAME = <nuevo>
```

Fase 2: Deshabilitar (Control 2.13)

```
ALTER LOGIN [<nuevo>]  
DISABLE
```

Fase 3: Prevenir (Control 2.16)

Asegurar que ninguna aplicación recree la cuenta verificando:

```
SELECT principal_id  
FROM sys.server_principals  
WHERE name = 'sa'
```


Contención y Prevención de Fugas

Control 2.15: AUTO_CLOSE en OFF

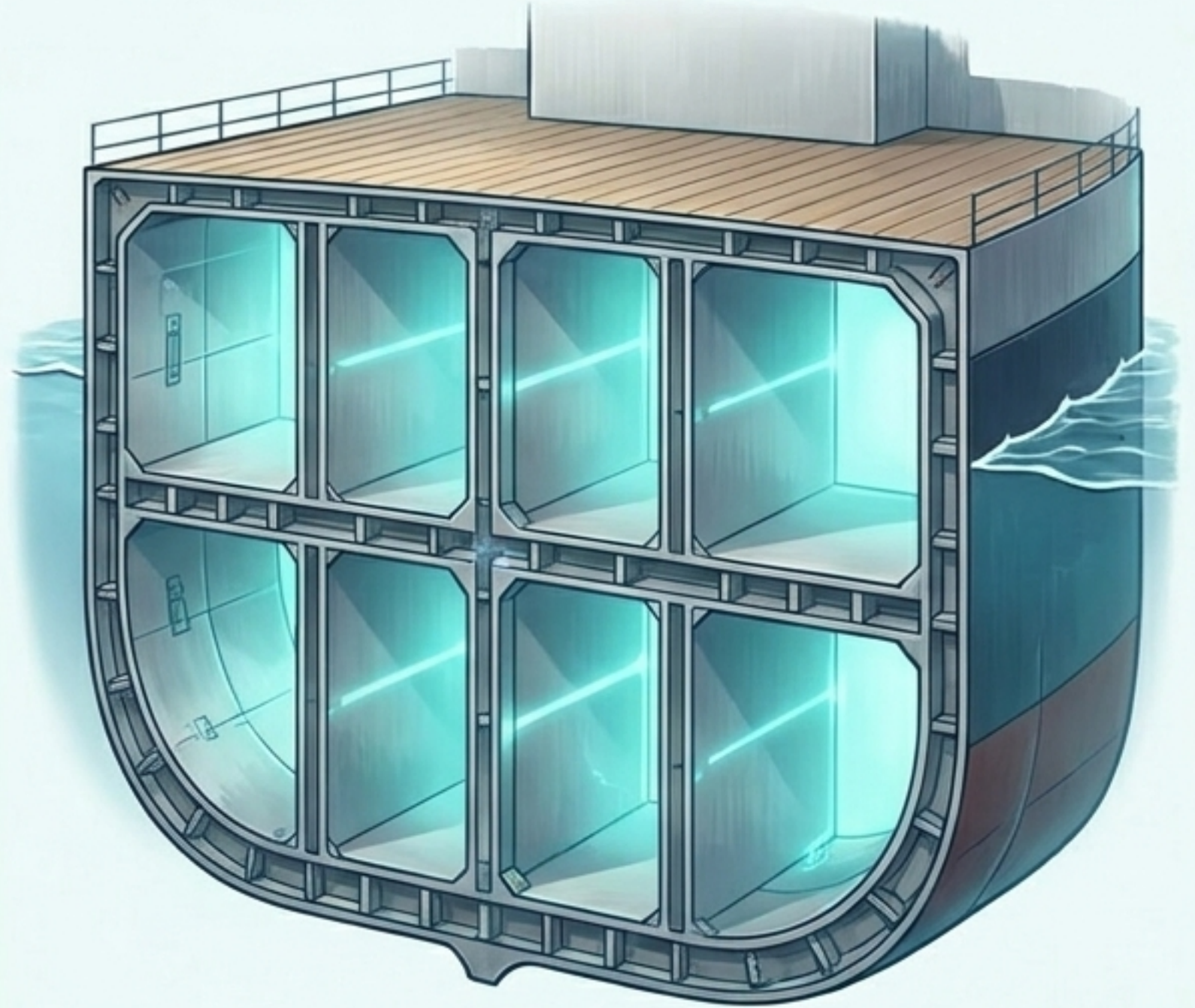
En bases de datos contenidas, AUTO_CLOSE obliga a reconstruir cachés repetidamente, abriendo la puerta a ataques de Denegación de Servicio (DoS). Forzar siempre a OFF.

Control 2.9: TRUSTWORTHY en OFF

Evita que objetos de una base de datos accedan a objetos de otra, protegiendo contra ensamblas CLR maliciosas. Excepción: la base de datos msdb.

Control 2.17: CLR Strict Security en 1

Obliga al motor a aplicar restricciones severas a todas las ensamblas, tratando las marcadas como seguras como UNSAFE por defecto.



El Motor de Auditoría: Automatización de Cumplimiento

Validación de Superficie de Ataque

```
SELECT name, value_in_use  
FROM sys.configurations  
WHERE name IN ('clr enabled', 'cross db ownership chaining', 'Database Mail XPs');
```

→ Todas las filas deben devolver 0

Validación de Identidad ('sa')

```
SELECT is_disabled  
FROM sys.server_principals  
WHERE sid = 0x01;
```

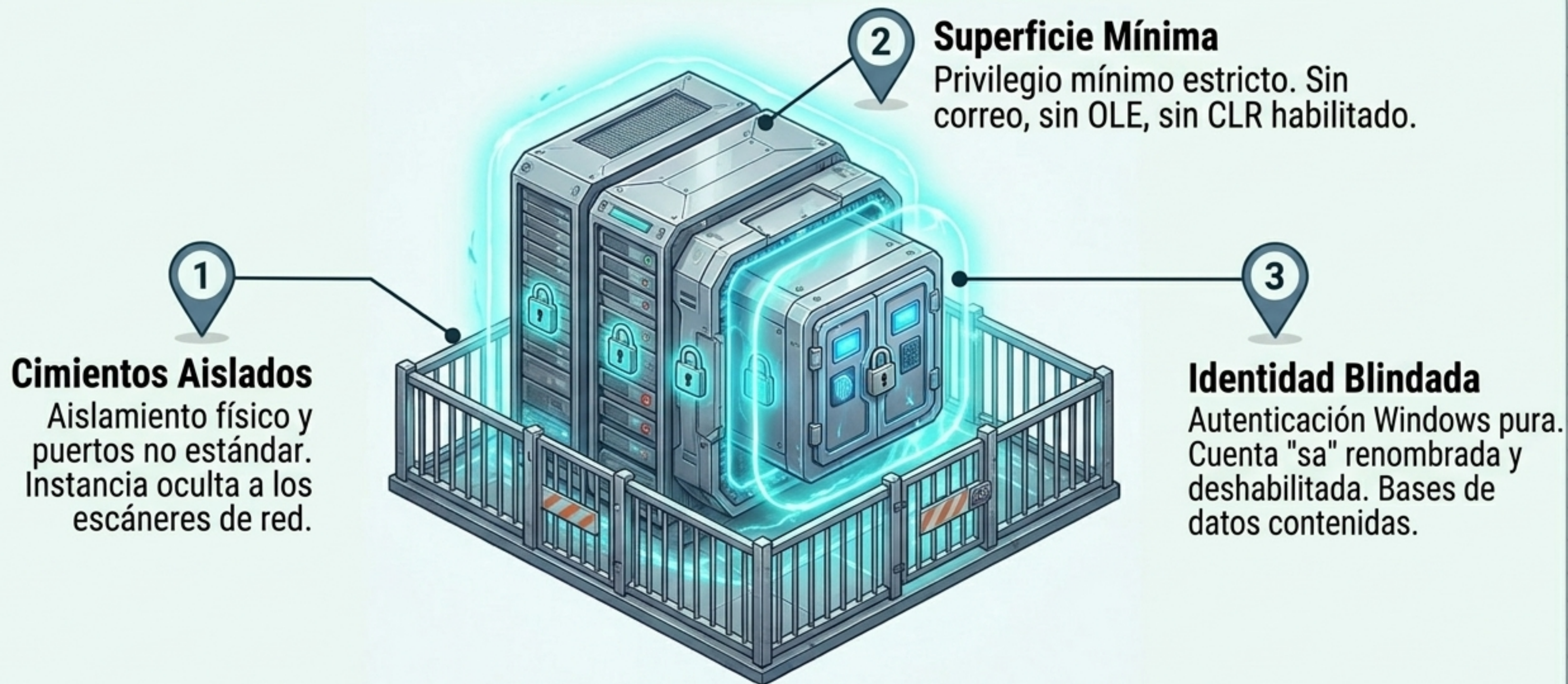
→ Debe retornar 1 (Deshabilitado)

Validación de Aislamiento

```
SELECT name FROM sys.databases  
WHERE is_trustworthy_on = 1 AND name != 'msdb';
```

→ Debe devolver 0 filas

Síntesis: El Servidor Fortificado



El cumplimiento del benchmark CIS transforma un motor rico en funciones en una bóveda de datos impenetrable.

Más allá del 'Setup': Monitoreo Continuo



Integración CIS Controls v8

La configuración segura no es un estado estático. Requiere revisión anual y automatización continua.

Siguientes Pasos Operativos:

1. Integrar los scripts de auditoría (sys.configurations) en las herramientas de monitoreo continuo (SIEM).
2. Probar siempre los impactos de utilidad (Ej. Perfil Nivel 2) en entornos de pre-producción antes de aplicar las reducciones de superficie en producción.
3. Mantener un inventario estricto de software soportado.

La seguridad de los datos es la base de la continuidad del negocio. Mantenga su fortaleza.